GETAMAZEDNOW AI
PRACTICAL AI. POSSIBLE FUTURES.
A GETAMAZEDNOW COMPANY

ADSRA

Five Open Questions

A consultation pack for clients and practitioners

Australian Digital Sovereignty Reference Architecture · v0.3 workstream

ABOUT THIS PACK

Five open questions

The Australian Digital Sovereignty Reference Architecture (ADSRA) is an open, vendor-neutral reference model for governing where data and AI workloads live — and for evidencing that governance to regulators. As it moves through its v0.3 draft, five questions remain deliberately open.

This pack puts those questions to clients and practitioners for structured input. Each is a genuine design or evidence question: your challenge, worked examples and sector experience shape the next version directly.

How your input is used

Each question sets out our current position — clearly labelled as a considered view, open to challenge, not settled fact — and describes what a strong contribution looks like. Where a question turns on regulatory obligations, those obligations are traced to primary sources in the full ADSRA Technical Reference.

The strongest contributions are concrete: a named workload, a worked estate, a specific service and region. Anecdote helps; evidence decides.

ADSRA · OPEN QUESTION OQ-1

How many data-classification tiers are right?

The question

Should sovereignty classification use four tiers (Low → Medium → High → Critical), or should the Medium tier split into commercial-sensitive versus personal data?

Why it matters

Classification is the engine of the architecture — it prices every control. Too few tiers and personal data hides inside a commercial tier, under-protected and exposed to the statutory tort of privacy; too many and the scheme collapses into over-classification, a known anti-pattern. Retail loyalty and behavioural data, and superannuation member data, are the pressure points.

Our current position *[a considered view, open to challenge]*

Four tiers, held. We already place retail loyalty behaviour at High — the primary privacy exposure after payment data — rather than Medium. A Medium split is plausible, but it must earn its added complexity.

What we're seeking from you

A worked example from your estate where a single Medium tier demonstrably mis-prices either commercial-sensitive or personal data — ideally with the control-cost consequence quantified.

Where this is most relevant: Retail · Financial services & superannuation

ADSRA · OPEN QUESTION OQ-2

Hold-your-own-key: surgical or broad?

The question

The architecture recommends that hold-your-own-key (HYOK) and client-side encryption be applied "surgically, not universally." Is that the right line?

Why it matters

HYOK and client-side encryption are the strongest cryptographic-sovereignty controls — and the most expensive. They break real native cloud features: server-side search, some analytics, managed integrations. The "surgical" guidance is a deliberate honest trade-off that needs field evidence, not assertion.

Our current position *[a considered view, open to challenge]*

Apply client-side encryption / HYOK only to assets whose threat model includes lawful compulsion of the cloud provider. Provider-managed keys for Low; customer-managed keys for Medium and High; HSM-backed customer-managed keys or HYOK for Critical. Applying it everywhere is self-harm.

What we're seeking from you

A named workload with the before-and-after feature loss and the risk it bought — either vindicating "surgical", or showing a class of workload where broader application paid off.

Where this is most relevant: Banking · Healthcare · Cross-industry / platform engineering

ADSRA · OPEN QUESTION OQ-3

Autonomous sovereignty: who audits the auditor?

The question

At the highest maturity level, AI agents assess and remediate the organisation's own sovereignty posture. What evidence would convince a regulator that this agentic remediation is itself well-governed?

Why it matters

This is the model's most novel contribution and its biggest exposure: the assurance system is itself an AI system, so it needs the same governance as any other AI workload — registered models, scoped tool permissions, budget limits, evidence trails. Without a regulator-credible evidence answer, autonomous assurance stays a slide, not a control. APRA's April 2026 AI letter points the same way: it expects second-line functions able to assess autonomous workflows, and monitoring proportionate to criticality.

Our current position *[a considered view, open to challenge]*

Treat it as aspirational by design — pilots, not production, are the realistic target inside a 24-month planning window. Agentic assurance must be governed as an AI workload, and depends on strong observability as its telemetry substrate.

What we're seeking from you

A concrete evidence package a regulator would accept for autonomous remediation: audit-trail schema, human-oversight thresholds proportionate to blast radius, fail-safe behaviours, and model / tool governance.

Where this is most relevant: Risk & regulatory practitioners · Banking

ADSRA · OPEN QUESTION OQ-4

Utilities and education: are the drafted blueprints right?

The question

Utilities and education blueprints were deferred from the first release and are now drafted in full. Are they right — and who can correct and extend them?

Why it matters

Both are priority verticals. Utilities (energy, gas, water) now sit under the enhanced critical-infrastructure risk-management rules (from 10 June 2026); education carries distinct student-data, children's-privacy and research-data profiles. A blueprint written without sector practitioners is the likeliest to be wrong.

Our current position *[a considered view, open to challenge]*

Drafted, not settled. The blueprints are our considered view — marked as such in the Technical Reference — and we are explicitly inviting practitioners who live these sectors to correct them.

What we're seeking from you

Corrections, or a co-author, for each blueprint — anchor obligations, Critical-tier assets, signature patterns and the worked example: named workloads, real obligations, and what we have got wrong.

Where this is most relevant: Utilities (energy) · Education

ADSRA · OPEN QUESTION OQ-5

Cloud-service mappings: what needs correcting?

The question

The indicative AWS / Azure / GCP mappings evolve quarterly. Which need correction against current Australian-region service capability before publication?

Why it matters

The mappings are labelled indicative, not endorsements — but stale mappings erode credibility with an engineering audience fastest. This is the lowest-controversy, highest-hygiene item: verification work, not a debate.

Our current position *[a considered view, open to challenge]*

Mappings are examples current at the time of writing. Validate service capabilities and regions before any design commitment — they are not endorsements. In-region AI-model availability is acknowledged to lag the global frontier; keep that caveat visible.

What we're seeking from you

Practitioner corrections naming the service, the Australian region, and the current capability (for example: customer-managed-key / HSM support, in-region model availability, policy-as-code primitives) versus what the draft states.

Where this is most relevant: Cross-industry · Cloud / platform engineering

AT A GLANCE

The five questions at a glance

Open question	What we're seeking	Most relevant
OQ-1 — How many data-classification tiers are right?	A worked example from your estate where a single Medium tier demonstrably mis-prices either commercial-sensitive or personal data — ideally with the control-cost consequence quantified.	Retail · Financial services & superannuation
OQ-2 — Hold-your-own-key: surgical or broad?	A named workload with the before-and-after feature loss and the risk it bought — either vindicating "surgical", or showing a class of workload where broader application paid off.	Banking · Healthcare · Cross-industry / platform engineering
OQ-3 — Autonomous sovereignty: who audits the auditor?	A concrete evidence package a regulator would accept for autonomous remediation: audit-trail schema, human-oversight thresholds proportionate to blast radius, fail-safe behaviours, and model / tool governance.	Risk & regulatory practitioners · Banking
OQ-4 — Utilities and education: are the drafted blueprints right?	Corrections, or a co-author, for each blueprint — anchor obligations, Critical-tier assets, signature patterns and the worked example: named workloads, real obligations, and what we have got wrong.	Utilities (energy) · Education
OQ-5 — Cloud-service mappings: what needs correcting?	Practitioner corrections naming the service, the Australian region, and the current capability (for example: customer-managed-key / HSM support, in-region model availability, policy-as-code primitives) versus what the draft states.	Cross-industry · Cloud / platform engineering